Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution

List of team members

S.NO	NAME	COLLEGE NAME	CONTACT
1.	**Danya S**	**Sri Ramakrishna college of arts and science for women**	**srcw2322k105@srcw.ac.in**
2	Harini V	Sri Ramakrishna college of arts and science for women	Srcw2322k115@srcw.ac.in
3	Dharshini S	Sri Ramakrishna college of arts and science for women	srcw2322k110@srcw.ac.in
4	Ishwarya S	Sri Ramakrishna college of arts and science for women	srcw2322k116@srcw.ac.in

Project details

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution.

In today's digital economy, organizations are undergoing rapid transformation driven by cloud computing, remote work, and the growing reliance on distributed applications. Traditional network architectures—built around centralized data centers and perimeter-based security—are no longer adequate to support this modern IT environment. One of the most significant components of this outdated architecture is the legacy Virtual Private Network (VPN), which was originally designed to provide secure remote access to internal corporate networks. While VPNs served organizations well in the past, they now present numerous limitations in terms of security, scalability, performance, and operational complexity.

Legacy VPN solutions operate on the assumption that once users are authenticated and connected to the corporate network, they can be trusted to access internal resources. This model extends the corporate network perimeter to remote devices, allowing users to connect to the network and access applications as if they were physically present inside the organization. However, this approach introduces significant security risks. Once a VPN connection is established, users often gain broad network-level access, which increases the potential for lateral movement by attackers if a device becomes compromised. In modern threat environments where cyberattacks are increasingly sophisticated, this "trust after verification" model is no longer sufficient to protect sensitive data and critical systems.

Additionally, legacy VPN architectures struggle to support the needs of a highly distributed workforce. With employees, partners, and contractors accessing applications from various

locations and devices, organizations must ensure secure connectivity without sacrificing performance or user experience. Traditional VPNs typically route traffic through centralized gateways or data centers, which can create network congestion, latency, and bottlenecks—particularly when users are geographically distant from these gateways. As businesses increasingly adopt cloud-based applications and Software-as-a-Service (SaaS) platforms, backhauling traffic through corporate data centers becomes inefficient and costly.

Another challenge associated with legacy VPN solutions is scalability. During periods of high demand—such as large-scale remote work adoption—organizations often struggle to scale VPN infrastructure quickly enough to accommodate thousands of simultaneous connections.

Expanding VPN capacity requires additional hardware, licensing, and network resources, leading to increased operational costs and administrative complexity. Furthermore, managing VPN policies, authentication mechanisms, and security updates across multiple locations can place a significant burden on IT teams.

To address these challenges, many organizations are transitioning toward a Zero Trust security model. Zero Trust is based on the principle of "never trust, always verify," which means that no user, device, or application is automatically trusted, regardless of whether it resides inside or outside the corporate network. Instead of granting broad network access, Zero Trust solutions enforce granular, identity-based access controls that allow users to connect only to the specific applications they are authorized to use. This approach significantly reduces the attack surface and prevents unauthorized lateral movement within the network.

A cloud-native Zero Trust platform provides an effective way to replace legacy VPN architectures while improving security, scalability, and performance. Cloud-native solutions are built to operate in distributed environments and leverage globally distributed infrastructure to deliver secure connectivity closer to users and applications. Rather than relying on centralized gateways, these platforms use cloud-based enforcement points that dynamically authenticate users, inspect traffic, and enforce security policies in real time.

One of the leading solutions in this space is the cloud-native Zero Trust platform offered by Zscaler. Designed specifically for modern enterprises, Zscaler's architecture eliminates the need for traditional VPN connections by providing secure, direct access to applications without exposing the corporate network to the internet. The platform leverages a globally distributed cloud security infrastructure that connects users to applications through secure,

policy-driven tunnels, ensuring that access is granted only after identity, device posture, and contextual factors have been verified.

Unlike legacy VPN solutions, the Zscaler Zero Trust architecture does not place users on the corporate network. Instead, it creates a secure, one-to-one connection between the authenticated user and the specific application they need to access. This application-level segmentation prevents unauthorized access to other resources and significantly reduces the risk of internal network compromise. By eliminating inbound connections and hiding applications from the public internet, the platform also helps organizations mitigate threats such as ransomware, credential theft, and distributed denial-of-service (DDoS) attacks.

Abstract:

As organizations continue to adopt cloud computing, mobile workforces, and distributed applications, traditional network security models based on legacy Virtual Private Networks (VPNs) are becoming increasingly ineffective. Legacy VPN architectures were originally designed to provide secure remote access to internal corporate networks by creating encrypted tunnels between users and centralized data centers. While this approach was sufficient in the past, the rapid shift toward cloud-based services, remote work environments, and modern digital infrastructures has exposed several limitations of VPN-based security models. These limitations include increased security risks, poor scalability, network performance issues, and complex infrastructure management.

Traditional VPN solutions follow a perimeter-based security approach that assumes users inside the corporate network can be trusted after authentication. Once a VPN connection is established, users are typically granted broad access to internal network resources. This network-level access increases the attack surface and creates opportunities for cyber attackers to move laterally across systems if a device or credential becomes compromised. With the rise of sophisticated cyber threats such as ransomware, phishing attacks, and credential theft, this security model is no longer sufficient to protect enterprise environments.

To address these challenges, organizations are increasingly adopting the Zero Trust security model, which is based on the principle of “never trust, always verify.” Zero Trust eliminates the concept of implicit trust within the network and instead requires continuous verification of users, devices, and applications before access to resources is granted. Rather than providing full network access, Zero Trust enforces granular, identity-based policies that allow

users to connect only to the specific applications they are authorized to access. This approach significantly reduces the risk of unauthorized access and limits potential damage from security breaches.

A cloud-native Zero Trust platform offers an effective solution for replacing legacy VPN infrastructures while improving security, scalability, and user experience. Unlike traditional network security systems that rely on centralized gateways and hardware appliances, cloud-native platforms leverage globally distributed cloud infrastructure to provide secure and direct connectivity between users and applications. This architecture enables organizations to deliver consistent security policies regardless of user location, device type, or application environment.

Use Case Scenarios:

Scenario 1: Secure Remote Employee Access

A company has employees working remotely from different locations. Previously, employees used a traditional VPN to connect to the corporate network. This caused slow performance, network congestion, and security risks because once users connected through the VPN, they could access many internal resources.

Output:

- Secure access to internal applications without network exposure
- Reduced risk of lateral movement in case of compromised devices
- Faster application performance due to direct cloud access
- Improved user experience for remote workers

Scenario 2: Secure Access for Third-Party Vendors

Organizations often allow vendors or contractors to access specific internal applications such as project management systems or databases. In a traditional VPN model, vendors receive network-level access, which increases the risk of unauthorized data exposure.

Output:

- Controlled access limited to specific applications

- Reduced security risks from external users
- Improved visibility of vendor activity
- Better compliance with security policies

Scenario 3: Secure Cloud Application Access

Many organizations use cloud applications such as SaaS platforms. In traditional networks, user traffic is routed through corporate data centers before reaching cloud services, which creates delays and inefficiencies.

Output:

- Faster access to cloud applications
- Reduced network latency and bandwidth consumption
- Improved productivity for employees
- Consistent security policies across all cloud applications

Scenario 4: Secure Access for Branch Offices

Companies with multiple branch offices traditionally use VPN tunnels or MPLS connections to connect each branch to the central data center. This increases infrastructure cost and management complexity.

Output:

- Reduced dependency on expensive MPLS networks
- Simplified branch connectivity
- Centralized policy management
- Improved network scalability and flexibility

Scenario 5: Protection Against Ransomware and Cyber Threats

Traditional VPN networks expose internal applications to the internet, which increases the risk of cyberattacks such as ransomware and credential theft. Attackers who compromise a user account can potentially move laterally across the network.

Output:

- Reduced attack surface
- Protection against ransomware and credential-based attacks
- Continuous monitoring of user behavior

Stage-1

Title Of the Project: -

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution

Overview: -

In modern enterprise environments, organizations increasingly depend on remote access technologies to support distributed workforces, cloud services, and digital collaboration. Traditionally, Virtual Private Networks (VPNs) have been widely used to provide secure connectivity between remote users and corporate networks. While VPNs were once considered a reliable solution for protecting remote access, the evolution of cyber threats and the growing adoption of cloud-based applications have exposed significant vulnerabilities in legacy VPN architectures. These vulnerabilities have made traditional VPN models less effective in securing modern enterprise networks.

One of the primary vulnerabilities of legacy VPN architectures is the overly broad network access granted to authenticated users. In a traditional VPN setup, once a user successfully authenticates, they are typically granted access to the entire internal network or large segments of it. This model assumes that users within the network can be trusted. However, if a malicious actor gains access to a legitimate user's credentials or compromises a device, they can exploit this trust to move laterally across the network and access sensitive systems. This

vulnerability significantly increases the attack surface and makes it easier for attackers to escalate privileges and extract valuable data.

Another major vulnerability lies in the exposure of VPN gateways to the public internet. VPN servers must be accessible from external networks in order to allow remote users to connect. As a result, these gateways often become attractive targets for cyber attackers who attempt to exploit software vulnerabilities, conduct brute-force login attempts, or launch denial-of-service attacks. Over the years, several high-profile security incidents have involved attackers exploiting vulnerabilities in VPN appliances to gain unauthorized access to corporate networks.

Legacy VPN architectures also suffer from limited visibility and control over user activity. Once users are connected to the network through VPN, it becomes difficult for administrators to monitor exactly which applications or resources are being accessed. This lack of granular visibility makes it challenging to detect suspicious behavior or unauthorized access in real time. Additionally, traditional VPN solutions often rely on static access policies that do not dynamically adjust based on contextual factors such as user location, device health, or behavioral patterns.

Another vulnerability associated with traditional VPN systems is inadequate device security verification. VPN authentication mechanisms typically verify user credentials but do not always evaluate the security posture of the connecting device. If a user connects from a compromised or malware-infected device, the VPN tunnel may unintentionally provide attackers with a secure pathway into the corporate network. This issue becomes particularly critical in environments where employees use personal devices or unmanaged systems to access corporate resources.

Scalability and infrastructure limitations also contribute to vulnerabilities in legacy VPN architectures. During periods of high remote access demand, VPN gateways may become overloaded, forcing organizations to quickly expand capacity or relax certain security controls. In some cases, administrators may bypass strict authentication mechanisms or reduce monitoring measures to maintain connectivity. Such adjustments can weaken overall security and increase the likelihood of unauthorized access.

Additionally, legacy VPN infrastructures are not designed for modern cloud-first environments. Many applications are now hosted in public or hybrid cloud environments rather than within corporate data centers. Routing all remote traffic through centralized VPN

gateways can create inefficient network paths and increase latency. This architecture not only reduces performance but also complicates the enforcement of consistent security policies across distributed applications.

List Of Vulnerability Table:

S.no	Vulnerability Name	CWE-No
1	Improper Link Resolution Before File Access	CWE-59
2	External Control of System or Configuration Setting	CWE-15
3	Reliance on Component That is Not Updateable	CWE-1329
4	Key Management Errors (Prohibited)	CWE-320
5	Improper Neutralization of Special Elements used in a Command ('Command Injection')	CWE-77
6	Incorrect Privilege Assignment	CWE-266
7	Authentication Bypass Using an Alternate Path or Channel	CWE-288

8	Uncontrolled Search Path Element	CWE-427
9	Insertion of Sensitive Information into Log File	CWE-532
10	Improper Handling of Extra Parameters	CWE-235

REPORT

1. Improper Link Resolution Before File Access (CWE-59)

Description

This vulnerability occurs when an application resolves symbolic links incorrectly before accessing files. Attackers can manipulate symbolic links to redirect the application to unintended files or sensitive system resources.

Business Impact

Possible consequences include:

- Unauthorized file access
- Disclosure of sensitive data
- Modification of system files
- Privilege escalation

This vulnerability may allow attackers to access protected files through manipulated links.

Steps to Reproduce

1. Identify file operations performed by the application.
2. Create a symbolic link pointing to a sensitive file.
3. Replace the expected file path with the symbolic link.
4. Execute the application.

If the application accesses the linked sensitive file, the vulnerability exists. **Practice Platform:** bWAPP Website: http://www.itsecgames.com

Related practice modules:

- Local File Inclusion

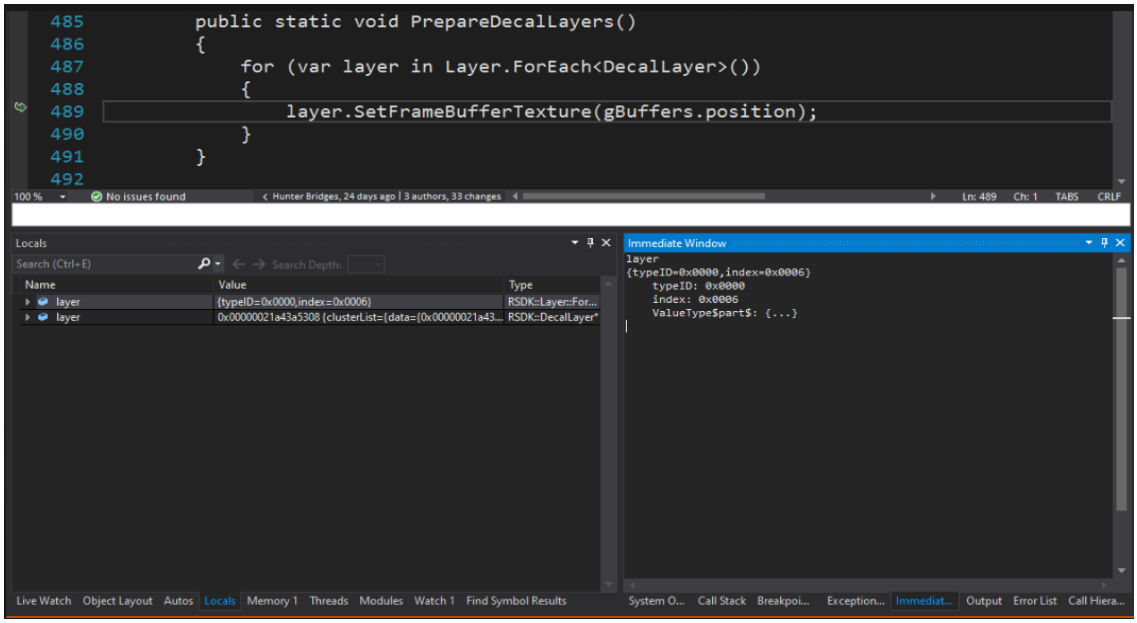
- Directory Traversal
- File Path Manipulation

These scenarios demonstrate how attackers manipulate file paths or symbolic links to access restricted files.

Recommendation

To mitigate this vulnerability, applications should strictly validate and sanitize all file path inputs before accessing system files. Developers should avoid using user-controlled inputs directly in files operations. Implementing proper access control mechanisms and restricting file access to predefined directories can prevent unauthorized file exposure. Additionally, symbolic links should be carefully validated before resolution to ensure that they do not redirect to sensitive system files. Security mechanisms such as file permission management, secure coding practices, and periodic security testing should be implemented to detect and prevent such vulnerabilities.

Screenshot



2. External Control of System or Configuration Setting (CWE-15)

Description

This vulnerability occurs when external users are allowed to modify system configuration settings. Attackers may change configuration parameters to alter the behavior of the application.

Business Impact

Possible consequences include:

- Unauthorized configuration changes
- System misconfiguration
- Security policy bypass
- Application malfunction

This vulnerability allows attackers to manipulate application settings for malicious purposes.

Steps to Reproduce

1. Identify configuration files or parameters used by the application.
2. Attempt to modify configuration values externally.
3. Restart or execute the application.
4. Observe whether the application behavior changes.

If external input can control system configuration, the vulnerability exists.

Practice Platform: OWASP Juice Shop
Website: https://juice-shop.herokuapp.com

Related scenarios:

- Security Misconfiguration
- Improper system configuration exposure
- Manipulating configuration values

These allow users to explore configuration weaknesses and header misconfigurations.

Recommendation

To prevent external control over system configuration settings, applications must ensure that configuration parameters cannot be modified by unauthorized users. Sensitive configurations should be stored securely on the server side and not exposed through client-side parameters. Access to configuration files must be restricted through proper permission settings and authentication mechanisms. Input validation and secure configuration management practices should be implemented to prevent manipulation of system settings. Regular security audits and vulnerability scanning can further help identify misconfigurations.

Understanding these risks through the **OWASP Top 10 framework** enables developers to build more secure applications and reduce the chances of configuration-based attacks.

Screenshot

(Insert configuration manipulation example)

```
private readonly string fileConnString = ConfigurationManager.AppSettings.Get("ConnectionString");
private OleDbConnection GetFileConnection(string file)
{
    // Validate path
    if (File.Exists(file))
    {
        OleDbConnectionStringBuilder builder = new OleDbConnectionStringBuilder(fileConnString)
        {
            ["data source"] = file
        };
        return new OleDbConnection(builder.ConnectionString);
    }
    else
    {
        MessageBox.Show(string.Format("File doesn't exist: {0}.", file));
    }

    return null;
}
```

3. Reliance on Component That Is Not Updateable (CWE-1329)

Description

This vulnerability occurs when an application depends on software components that cannot be updated or patched. If vulnerabilities are discovered in these components, they remain exploitable.

Business Impact

Possible consequences include:

- Exposure to known vulnerabilities
- Increased attack surface
- Long-term security risks
- System compromise

This vulnerability makes the system vulnerable to exploits targeting outdated components.

Steps to Reproduce

1. Identify third-party components used by the application.
2. Check if the component supports updates or patches.
3. Verify known vulnerabilities in the component.
4. Attempt to exploit the known weakness.

If the component cannot be updated or patched, the vulnerability exists.

Practice Platform: OWASP Broken Web Applications
Website: https://owasp.org/www-project-broken-web-applications/

This VM contains:

- Outdated software

- Vulnerable libraries
- Legacy web applications

Useful for demonstrating **vulnerable and outdated components**.

Recommendation

Organizations should ensure that all third-party components, libraries, and frameworks used in applications are regularly updated and maintained. Software components that cannot be updated should be replaced with supported alternatives. Developers should monitor vulnerability databases and security advisories to identify known vulnerabilities in third-party components. Implementing automated dependency scanning tools and maintaining a proper software inventory can help manage outdated components effectively. Secure software lifecycle practices should also be followed to minimize risks related to outdated technologies.

Following **OWASP Top 10 guidelines** helps organizations identify risks associated with vulnerable and outdated components and implement proper patch management strategies.

Screenshot

4. Key Management Errors (Prohibited) (CWE-320)

Description

This vulnerability occurs when cryptographic keys are improperly generated, stored, or managed. Weak key management practices can allow attackers to access encrypted data.

Business Impact

Possible consequences include:

- Decryption of sensitive information
- Data theft
- Unauthorized system access
- Compromise of secure communication

Improper key management can completely break cryptographic protection.

Steps to Reproduce

1. Identify cryptographic key storage methods.
2. Check whether keys are stored in plaintext or insecure locations.
3. Attempt to access the stored keys.
4. Use the key to decrypt protected data.

If keys are easily accessible or poorly protected, the vulnerability exists.

Practice Platform: DVWA
Repository: https://github.com/digininja/DVWA

Related labs include:

- Weak cryptographic storage
- Poor password handling
- Insecure encryption implementations

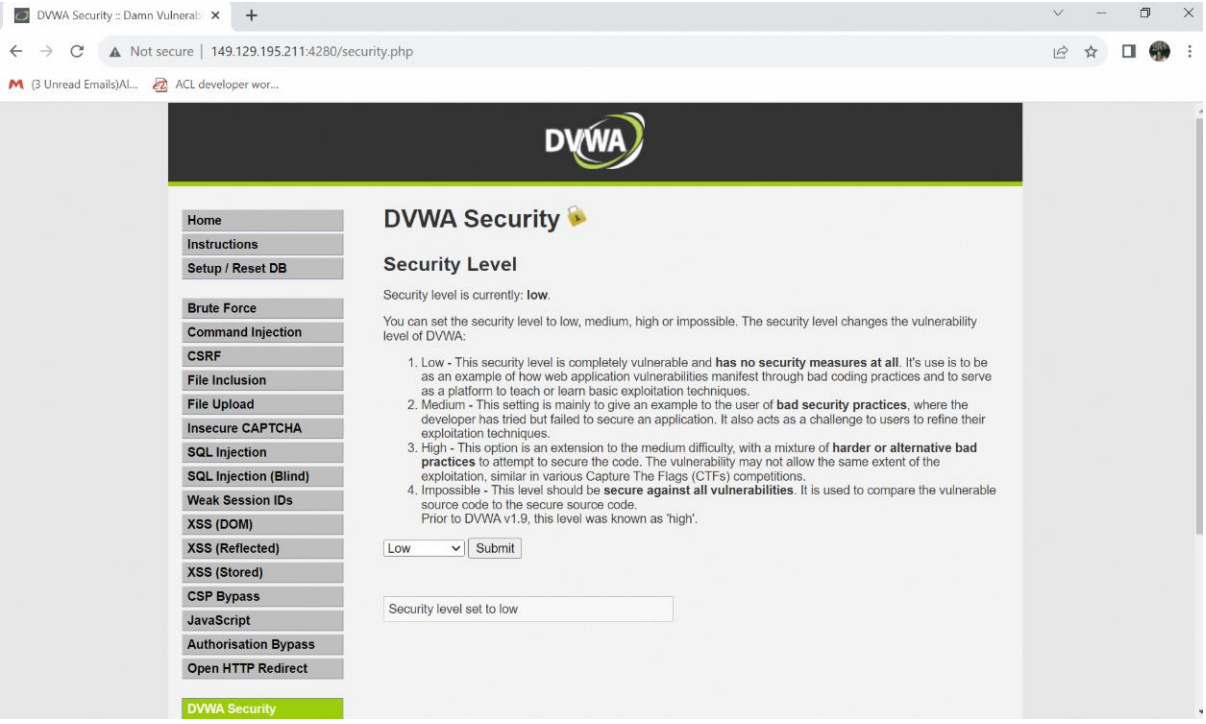
These help demonstrate cryptographic weaknesses.

Recommendation

Proper cryptographic key management practices should be implemented to protect sensitive data. Encryption keys must never be hardcoded within application source code or configuration files. Instead, secure key management systems such as hardware security modules (HSMs) or secure vault services should be used to store and manage cryptographic keys. Strong encryption algorithms and secure key rotation policies should also be enforced. Access to cryptographic keys must be restricted through strict authentication and

authorization mechanisms. Regular security assessments should be conducted to ensure compliance with cryptographic best practices.

Screenshot



5. Command Injection (CWE-77)

Description

This vulnerability occurs when user input is not properly sanitized before being passed to system commands. Attackers can inject malicious commands that execute on the host system.

Business Impact

Possible consequences include:

- Remote command execution
- System compromise
- Data theft or modification
- Unauthorized administrative access

Command injection allows attackers to fully control the underlying system.

Steps to Reproduce

1. Identify input fields that interact with system commands.
2. Insert special characters or command operators.
3. Execute the request.
4. Observe whether additional commands are executed.

If injected commands run successfully, the vulnerability exists.

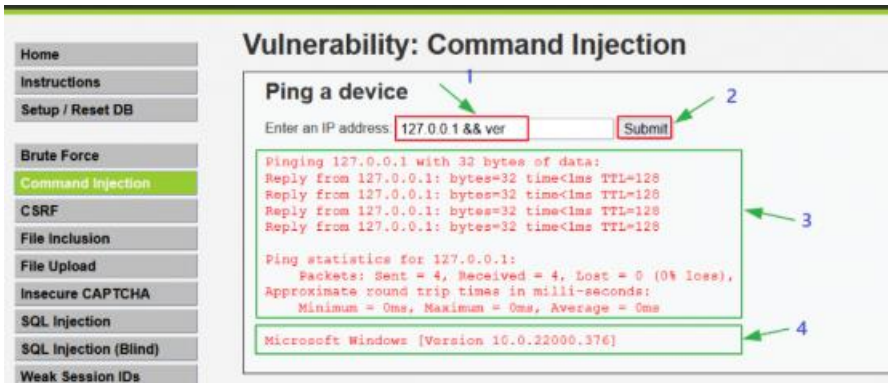
Practice Platform: DVWA
Also available in: bWAPP

Example labs:

- OS Command Injection
- System command execution

To prevent command injection vulnerabilities, applications should avoid directly executing system commands using user-supplied input. All input should be strictly validated, sanitized, and filtered to remove potentially malicious characters or command separators. Developers should use secure APIs and parameterized commands rather than constructing command strings dynamically. Implementing least-privilege principles for system processes can further reduce the impact of potential attacks. Additionally, employing web application firewalls (WAF) and intrusion detection systems can help detect and block malicious command injection attempts.

Screenshot



6. Incorrect Privilege Assignment (CWE-266)

Description

This vulnerability occurs when privileges are incorrectly assigned to users or processes. Unauthorized users may gain elevated permissions.

Business Impact

Possible consequences include:

- Unauthorized administrative access
- Data manipulation
- Privilege escalation
- System compromise

Improper privilege assignment can allow attackers to access restricted functionality.

Steps to Reproduce

1. Identify user roles and permissions.
2. Log in as a low-privileged user.
3. Attempt to access restricted resources.
4. Check whether access is granted.

If restricted actions are allowed, the vulnerability exists.

Practice Platform: OWASP Juice Shop

Related labs:

- Privilege escalation
- Admin panel access bypass
- Unauthorized role access

These scenarios demonstrate improper permission controls.

Recommendation

Applications should implement robust access control mechanisms to ensure that users are granted only the permissions necessary to perform their tasks. Role-based access control (RBAC) or attribute-based access control (ABAC) models should be used to manage user privileges effectively. Privilege escalation risks can be minimized by regularly reviewing and auditing user permissions. Sensitive administrative functionalities should be restricted to authorized personnel only. Implementing strong authentication and monitoring access logs can help detect unauthorized privilege usage and ensure system security.

Screenshot

Privilege Escalation

- **Technique** Bypass User Account Control (T1088)
- **Detection** Monitor registry file modifications based on registry hijacking of CompMgmtLauncher.exe (UAC technique discovered by enigma0x3)

Initial Access
Execution
Persistence
Privilege Escalation
Command and Control
Defense Evasion
Credential Access
Discovery
Lateral Movement
Collection
Exfiltration
Impact

```
sequence with maxspan=10s
  [registry where length(bytes_written_string) > 0 and key_type in
    ("sz", "expandSz") and key_path == "*\\mscfile\\shell\\open\\command\\"
    and user_name != "SYSTEM"]
  [process where process_path == "C:\\Windows\\System32\\CompMgmtLauncher.exe"]
  [process where process_name in ("mshta.exe","rundll32.exe") and
    integrity level == "high"]
```

elastic

https://enigma0x3.net/2016/08/15/fileless-uac-bypass-using-eventvwr-exe-and-registry-hijacking/

7. Authentication Bypass Using an Alternate Path or Channel (CWE-288)

Description

This vulnerability occurs when attackers bypass authentication mechanisms by using alternate paths or channels to access protected resources.

Business Impact

Possible consequences include:

- Unauthorized system access
- Exposure of sensitive information
- Account compromise
- Data manipulation

This vulnerability allows attackers to bypass login mechanisms.

Steps to Reproduce

1. Identify authentication mechanisms used by the application.
2. Attempt to access restricted resources directly through alternate URLs or APIs.
3. Observe whether authentication checks are skipped.

If access is granted without authentication, the vulnerability exists.

Practice Platform: OWASP Mutillidae II
Website: https://owasp.org/www-project-mutillidae-2/

Practice scenarios:

- Login bypass
- Authentication flaws
- Session manipulation

Recommendation

Applications must enforce authentication checks consistently across all entry points, including APIs, direct URLs, and alternate access paths. Authentication mechanisms should be properly implemented using secure session management and token validation techniques. Multi-factor authentication (MFA) can add an additional layer of protection against unauthorized access. Developers should ensure that authentication logic is centralized and cannot be bypassed through alternative channels. Regular penetration testing and security assessments should be performed to identify potential authentication flaws.

Screenshot

8. Uncontrolled Search Path Element (CWE-427)

Description

This vulnerability occurs when the system loads resources from uncontrolled locations. Attackers can place malicious files in directories that the application searches for executables or libraries.

Business Impact

Possible consequences include:

- Execution of malicious code
- System compromise
- Privilege escalation
- Malware installation

This vulnerability allows attackers to manipulate the application execution process.

Steps to Reproduce

1. Identify application search paths.
2. Place a malicious executable in a searched directory.
3. Execute the application.
4. If the malicious file executes instead of the legitimate one, the vulnerability exist.

Practice Platform: OWASP Broken Web Applications

Includes systems where:

- Executable search paths can be manipulated
- Malicious files can replace legitimate ones
- **Recommendation**
- To mitigate uncontrolled search path vulnerabilities, applications should specify absolute paths when executing system programs or loading libraries. Developers must avoid relying on environment variables or system search paths that attackers could manipulate. Access permissions for executable directories should be restricted to prevent unauthorized file placement. System administrators should regularly review system paths and remove unnecessary directories from the execution path. Implementing application whitelisting and secure deployment practices can further reduce the risk of exploitation.
-

Screenshot

(Insert search path exploitation example)

```
[*] Started reverse handler on 192.168.0.133:4444
[*] Starting the payload handler...
[*] Sending stage (884270 bytes) to 192.168.0.138
[*] Meterpreter session 1 opened (192.168.0.133:4444 -> 192.168.0.138:1029) at 2
015-11-08 14:59:56 +0000

meterpreter > shell
Process 3096 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

9. Insertion of Sensitive Information into Log File (CWE-532)

Description

This vulnerability occurs when sensitive information such as passwords, tokens, or personal data is written into log files.

Business Impact

Possible consequences include:

- Exposure of confidential information
- Credential theft
- Unauthorized system access
- Data privacy violations

Attackers with log access can retrieve sensitive data.

Steps to Reproduce

1. Trigger application processes that generate logs.
2. Open the generated log files.
3. Check whether sensitive data is recorded.

Practice Platform: OWASP Juice Shop

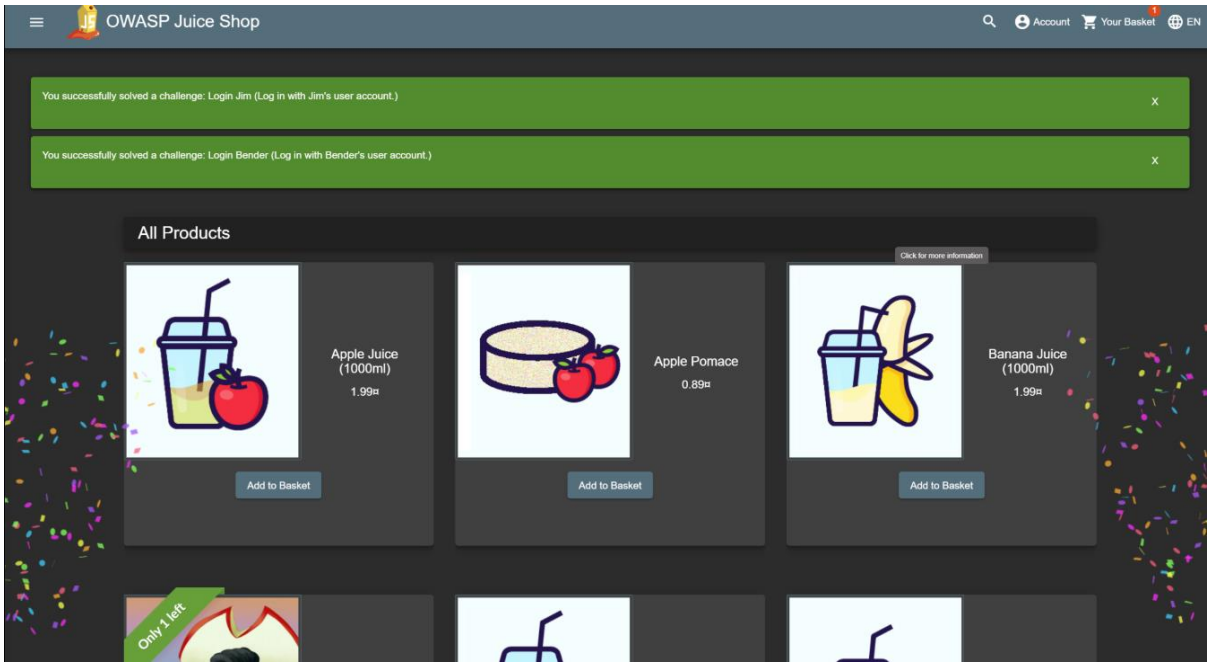
Examples:

- Sensitive information in logs
- Debug data exposure
- Token leakage
  Recommendation
  Applications should avoid logging sensitive information such as passwords, authentication tokens, personal data, or encryption keys. Logging mechanisms must

be carefully configured to ensure that only necessary operational information is recorded. Sensitive data should be masked or anonymized before being written to logs. Access to log files should be restricted through strict access control policies to prevent unauthorized viewing. Regular log monitoring and secure log management solutions should be implemented to protect sensitive information from exposure.

If confidential data appears in logs, the vulnerability exists.

Screenshot



10. Improper Handling of Extra Parameters (CWE-235)

Description

This vulnerability occurs when an application fails to properly validate or handle additional unexpected parameters in requests.

Business Impact

Possible consequences include:

- Manipulation of application logic
- Unauthorized actions
- Security control bypass
- Data integrity issues

Attackers may exploit extra parameters to change system behavior.

Steps to Reproduce

1. Identify request parameters used by the application.
2. Add additional unexpected parameters to the request.
3. Send the modified request to the server.
4. Observe the response.

If the application processes unexpected parameters, the vulnerability exists.

Practice Website:

- DVWA
- bWAPP

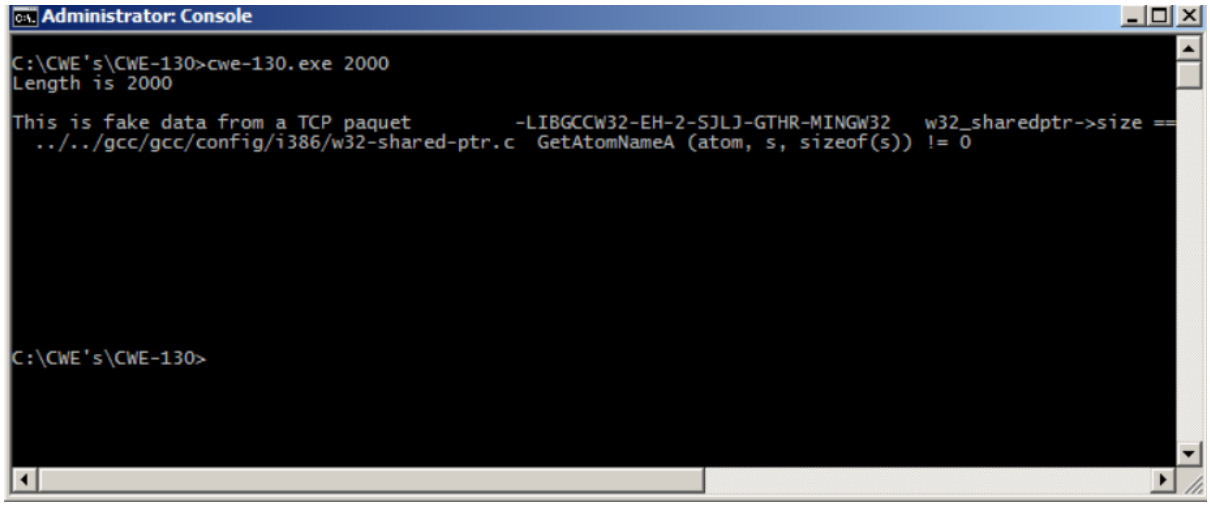
Examples:

- Parameter tampering
- Hidden parameter manipulation

Recommendation

Applications should implement strict input validation to ensure that only expected parameters are processed. Any additional or unexpected parameters should be rejected or ignored by the application. Developers should enforce strong parameter validation rules and utilize secure frameworks that automatically handle request validation. API endpoints must be designed to accept only predefined inputs and reject malformed requests. Regular security testing and code reviews should be conducted to identify parameter tampering vulnerabilities and ensure that application logic cannot be manipulated through unauthorized parameters.

Screenshot



Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices. When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually. Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP

. 2. Nessus sends a series of probes to the target host in order to identify its operating system and services.

3. Nessus runs a series of plugins to test for vulnerabilities.

4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability. Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts. Here are some of the benefits of using Nessus:

● Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

● Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

● Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.

● Flexibility: Nessus can be configured to run scans on a schedule or manually. Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/ Target ip address:- 65.61.137.117

List of vulnerability:-

S.no	Vulnerability Name	Severity	Plugin ID
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus ≤1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: - 1.

1.Vulnerability:- TLS 1.0 Protocol Supported

Severity: - Medium

Plugin ID:- 104743

Port:- 443

Description:- The scanned service allows encrypted communication using TLS version 1.0. This protocol contains several cryptographic weaknesses that can expose secure communications to potential attacks. Although some modern implementations attempt to mitigate these weaknesses, TLS 1.0 is considered obsolete and insecure compared to newer standards such as TLS 1.2 and TLS 1.3.

Major web browsers and technology vendors discontinued support for TLS 1.0 starting March 31, 2020. In addition, PCI DSS v3.2 mandates that organizations completely disable TLS 1.0 except in specific legacy POS scenarios where compensating controls exist.

Solution:-

Disable TLS 1.0 support on the affected service and configure the server to accept only TLS 1.2 or TLS 1.3 connections.

Business Impact:-

Using an outdated encryption protocol increases the risk of data exposure and cyberattacks. Attackers may exploit TLS 1.0 weaknesses to intercept sensitive communications. Furthermore, continued use of this protocol may lead to compliance violations with PCI DSS standards, potentially resulting in penalties and reputational damage. Updating to modern TLS versions improves security and ensures compatibility with modern browsers and applications.

2. Vulnerability:- TLS 1.1 Protocol Deprecated

Severity:- Medium

Plugin ID:- 157288

Port:- 443 Description The remote server supports TLS version 1.1, which is considered deprecated. TLS 1.1 does not support modern cryptographic algorithms or advanced cipher suites such as Authenticated Encryption with Galois/Counter Mode (GCM). This limitation reduces the strength of encrypted communications. Major browsers and vendors have also deprecated TLS 1.1 since March 2020, requiring servers to adopt TLS 1.2 or later for secure communications.

Solution:- Disable TLS 1.1 on the server and ensure that only TLS 1.2 and TLS 1.3 protocols are enabled for secure communication.

Business Impact:-

The continued use of TLS 1.1 weakens the organization's security posture and increases exposure to potential cryptographic attacks. In addition, systems that rely on outdated TLS versions may experience compatibility issues with modern browsers and external services. Remediating this issue helps maintain secure communications and ensures continued compatibility with modern technologies.

3)Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)
Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust

4)Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5)Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as : www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6)Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7)Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590 Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host. Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management.

8)Vulnerability Name: - Device Type Severity: -

INFO Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network.

This information aids in network management, optimization, and ensures that the right security measures are in place for each device type.

9)Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSLstripping man-in-the-middle attacks, and weakens cookie-hijacking protections. Solution: - Configure the remote web server to use HSTS.

Severity Business Impact: -Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-themiddle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

10) Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO Plugin: - 10107

Port: - 4434

Description: - This plugin attempts to determine the type and the version of the remote web server. Solution: - N/A

Business Impact: -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

• Legacy VPN Architecture

Legacy VPN architecture is a network security model that creates an encrypted tunnel between a remote user and an organization's internal network using on-premises hardware appliances like VPN concentrators . Unlike modern solutions, legacy VPNs operate on an "authenticate once, trust indefinitely" principle. Once a user successfully authenticates, they are placed directly onto the internal network with an IP address, effectively becoming a node on that network

. This architecture was designed for a different era when all users were in offices and all applications were in data centers. It relies on the concept of a "trusted internal network" versus an "untrusted external internet"—the castleand-moat model . The VPN concentrator acts as the drawbridge: once crossed, the user is trusted and granted broad access to internal resources based on their IP address rather than their identity .

• **Limitations of Legacy VPN Legacy VPN** architectures present significant security and operational challenges in today's distributed work environment. The limitations include: 1. Over-permissioned Access: Once connected, users gain network-level access, meaning a compromised faculty laptop can scan, discover, and attack other systems on the internal network (lateral movement) . 2. Expanded Attack Surface: VPN concentrators must be exposed to the public internet with open ports (typically IPsec on UDP 500 or SSL VPN on TCP 443), making them visible targets for port scanning, brute-force attacks, and vulnerability exploitation . 3. Poor User Experience: Traffic is often "hair-pinned"—routed from the user to the data center and then out to the internet for SaaS applications—causing latency and slow performance . 4. Scalability Challenges: Hardware VPN appliances have hard capacity limits. During peak times (e.g., start of semester), users face connection failures, requiring manual upgrades of expensive hardware . 5. Operational Overhead: IT staff

must patch, upgrade, and maintain physical VPN appliances, applying firmware updates and managing certificates .

• The Problem: Lateral Movement and Attack Surface

The core security weaknesses of legacy VPNs are the expanded attack surface and the risk of lateral movement. Attack Surface: The VPN concentrator's publicly exposed IP address and open ports invite constant scanning and attacks. Threat actors use tools to identify VPN appliances and exploit known vulnerabilities (e.g., CVE2019-11510, a critical Pulse Secure VPN vulnerability). Each exposed port is a potential entry point . Lateral Movement: Once an attacker gains access via a compromised credential or vulnerability, they inherit the user's network-level access. The internal network, traditionally flat, allows the attacker to move laterally. From a single compromised faculty laptop, they can

: • Scan for other vulnerable servers (e.g., databases, file shares)

• Perform ARP spoofing or pass-the-hash attacks

• Pivot to high-value targets like the student information system or research data repositories
• Deploy ransomware across the network

• Zero Trust Architecture

Zero Trust Architecture (ZTA) is a security framework that eliminates the concept of trusted and untrusted networks. It operates on the principle of "never trust, always verify" and "least privilege access." Every access request is fully authenticated, authorized, and encrypted before granting access, regardless of whether the user is in the office or working remotely .

The core tenets of Zero Trust include:

1. Assume Breach: Design the network as if attackers are already present

2. Verify Explicitly: Authenticate and authorize based on identity, device health, and context.

3. Least Privilege Access: Grant only the minimum access necessary to perform a job function.

4. Micro-segmentation: Isolate workloads and users from one another to prevent lateral movement

• Zscaler Zero Trust Solution

Zscaler is a cloud-native security platform that delivers Zero Trust capabilities entirely from the cloud, eliminating the need for on-premises VPN hardware. The solution consists of two primary components relevant to this project:

1. Zscaler Private Access (ZPA): A ZTNA service that provides seamless, identity-based access to private applications without placing users on the network. It connects users to applications, not the network .

2. Zscaler Internet Access (ZIA): A secure web gateway that inspects all internet-bound traffic for threats and data loss, protecting users regardless of location . Together, they create a comprehensive Zero Trust replacement for legacy VPN architectures.

>How Zscaler eliminates the attack surface

This is achieved through:

1. No Inbound Ports: Zscaler ZPA uses Zscaler App Connectors—lightweight VMs deployed in the data center—that initiate outbound connections to the Zscaler cloud. No inbound firewall ports need to be opened for remote access

2. Application Invisibility: To an external port scanner, the university's applications do not exist. There are no IP addresses to scan, no ports to probe, and no VPN concentrators to attack .

3. DNS Resolution: ZPA does not rely on public DNS to resolve internal application names. Applications are never exposed to the public DNS infrastructure .

4. Dark Cloud Principle: The Zscaler cloud acts as a broker. Users connect to the cloud, and the cloud connects to the application. The application server never sees the user’s IP, and the user never sees the server’s IP—only the application itself

. **• How Zscaler Prevents Lateral Movement**

Zscaler prevents lateral movement by ensuring users are connected to applications, not to the network.

The mechanisms include:

1. Application Segmentation: ZPA establishes a one-to-one, encrypted micro-tunnel between the user's device and the specific application they are authorized to access. The user never receives an IP address on the internal network .

2. No Network Visibility: Because the user is not placed on the network, they cannot scan, discover, or connect to other resources. There is no routing to adjacent systems. The network is invisible .

3. Identity-Based Micro-segmentation: Access policies are tied to user identity, not IP addresses. Even if an attacker compromises a user's credentials, they can only access the specific applications that user is authorized for—nothing else .

4. Continuous Monitoring: Zscaler monitors the connection throughout the session. If suspicious behavior is detected (e.g., impossible travel, anomalous data transfer), the connection can be terminated in realtime, preventing further movement .

• Zscaler Architecture Components

To understand how Zscaler replaces the legacy VPN, it is essential to understand its core components: 1. Zscaler Client Connector: A lightweight software client installed on user devices (laptops, desktops, mobile devices). It intelligently forwards traffic:

• Private application traffic → ZPA for secure access • Internet-bound traffic → ZIA for security inspection

• Bypassed traffic → Direct to internet (for performance) 2. Zscaler App Connector: A software component deployed as a VM in the university's data center or cloud environment. It initiates outbound connections to the Zscaler cloud and brokers connections to internal applications. Key features:

• No inbound firewall rules required

• Automatically scales horizontally based on load

• Can be deployed in multiple locations for high availability 3. Zscaler Cloud: The global security platform that enforces policies, brokers connections, and inspects traffic. It consists of over 150 data centers worldwide, ensuring low-latency access . 4. Zscaler Admin Portal: The centralized management console where administrators configure: • Access policies • Application definitions • User and group mappings • Security settings • Integration Points Zscaler integrates with existing university infrastructure to leverage current investments: 1. Identity Provider (IdP) Integration:

• Azure AD / Okta: Zscaler integrates with the university's existing IdP for user authentication and MFA. This ensures consistent identity management and allows users to use their existing credentials .

• SAML 2.0 / OpenID Connect: Supports modern authentication protocols for seamless single sign-on (SSO). 2. Endpoint Protection Integration:

• CrowdStrike / Microsoft Defender / Tanium: Zscaler checks device posture with integrated endpoint detection and response (EDR) tools. Access can be conditional on: o Antivirus running and up-to-date o Disk encryption enabled o OS patch level current o Device not jailbroken/rooted 3. SIEM/SOAR Integration:

• Splunk / Sentinel: Zscaler logs can be forwarded to the university's security information and event management (SIEM) system for centralized monitoring, alerting, and threat hunting . 4. Threat Intelligence Integration:

• MISP Integration: Zscaler can consume threat intelligence feeds from MISP to block access to known malicious domains, IPs, and URLs via ZIA .

• MISP (Malware Information Sharing Platform) Integration MISP is an open-source threat intelligence platform that enables sharing of indicators of compromise (IOCs) within the security community. Integrating MISP with Zscaler enhances threat detection capabilities.

1. Threat Intelligence Ingestion:

• MISP aggregates IOCs from multiple sources—industry ISACs, open-source feeds, and internal threat research .

• These IOCs include malicious domains, IP addresses, URLs, and file hashes associated with known malware campaigns, phishing attacks, and command-and-control (C2) servers .

2. Integration Mechanism:

• The security team configures MISP to push threat intelligence feeds to the Zscaler cloud via API .

• Zscaler normalizes this data into its threat intelligence database .

3. Proactive Blocking:

• When a faculty member—even one authorized via ZPA—attempts to access a website that matches an IOC from the MISP feed, ZIA blocks the request . 4. Enhanced Threat Correlation:

• Security analysts can use MISP to cross-reference Zscaler logs. For example, if anomalous outbound traffic is detected from a compromised device, analysts can query MISP to determine if the destination IP is associated with a known threat actor .

• Deployment Methodology Deploying Zscaler to replace the legacy VPN requires a structured, phased approach: Phase 1: Discovery and Planning (Weeks 1-2)

1. Application Discovery: Catalog all internal applications currently accessed via VPN. This includes: o Student Information System (SIS) o ERP (Finance/HR) o Library resources o Research computing clusters o Internal file servers o Administrative portals

2. User Segmentation: Define user groups and their application access requirements: o Faculty: ERP, research servers, file shares o Students: Library resources, learning management system o Staff: Administrative portals, finance applications o IT Admins: Server management interfaces o External Collaborators: Specific research applications only 3. Traffic Analysis: Understand current traffic patterns to plan Zscaler Internet Access (ZIA) forwarding methods (PAC file, tunnel, or proxy). Phase 2: Infrastructure Deployment (Weeks 3-4)

1. Deploy App Connectors: o Provision App Connector VMs in the university data center (minimum 2 for high availability) o Configure them with outbound internet access to connect to Zscaler cloud o No inbound firewall rules required

2. Configure App Connector Groups: o Group connectors by function or location o Associate them with specific applications for traffic steering 3. Integrate Identity Provider: o Configure SAML 2.0 between Zscaler and Azure AD o Map user groups from Azure AD to Zscaler o Test authentication flow Phase

3: Policy Configuration (Weeks 5-6) 1. Define Applications in ZPA: o Add each internal application (by IP, port, and protocol) o Associate applications with App Connector groups o Configure application segmentation

2. Create Access Policies: o Build granular policies based on user groups: ▪ "Faculty can access ERP on TCP 443 from devices with antivirus enabled after MFA" ▪ "Researchers can access HPC Cluster on TCP 22 from managed devices only"

▪ *"External Collaborators can access Research Repository on TCP 443 between 9 AM-5 PM"*

3. Configure ZIA Policies: o Set up URL filtering o Enable threat protection (IPS/IDS) o Configure data loss prevention (DLP) rules for sensitive data

Phase 4: Pilot Deployment (Weeks 7-8)

1. Select Pilot Group: Choose a small group of willing faculty and IT staff (10-20 users).

2. Deploy Zscaler Client Connector: Provide installation instructions and assist with setup.

3. Monitor and Validate: o Verify authentication and MFA flows o Test application access o Validate that users cannot access unauthorized applications o Collect feedback on performance

4. Refine Policies: Adjust based on pilot feedback and any access issues.

Phase 5: Full Deployment and Migration (Weeks 9-12)

1. Phased Rollout: Deploy to user groups in waves:

Week 9: Faculty and researchers o Week 10: Administrative staff o Week 11: Students (if applicable) o Week 12: IT staff and remaining users

2. Communication and Training: o Send pre-deployment emails with instructions o Provide user guides for Zscaler Client Connector o Establish support channels for issues

3. Legacy VPN Decommissioning: o Once all users are migrated, revoke legacy VPN access o Shut down VPN concentrators o Remove public DNS records pointing to VPN

Phase 6: Optimization and Continuous Improvement (Ongoing) 1. Log Analysis: Regularly review Zscaler logs in the admin portal for anomalies.

2. Policy Refinement: Update policies based on changing user roles and application additions.

3. Threat Hunting: Use integrated threat intelligence (MISP) to proactively search for compromised accounts.

• Threat Intelligence in Zscaler Environment Threat intelligence transforms Zscaler from an access control tool into a proactive security platform. It provides context about who is trying to access what, from where, and with what risk. Sources of Threat Intelligence:

1. Zscaler Cloud Logs:

Real-time data on connections, including: o User identity and group membership o Source IP and geolocation o Destination application and IP o Bytes transferred and session duration o Device posture information 2. External Threat Feeds (MISP): Structured IOCs from trusted sources: o Known malicious domains (e.g., phishing sites) o Command-and-control server IPs o Ransomware distribution URLs o File hashes of malware samples

3. Identity Provider Logs: Authentication data from Azure AD: o Successful and failed login attempts o MFA status o Impossible travel anomalies

4. EDR Integration: Endpoint detection tools provide: o Compromised device alerts o Malware detections o Anomalous process behavior Applications of Threat Intelligence: 1. Adaptive Access Control: o If threat intelligence identifies a user's source IP as high-risk (e.g., known TOR exit node or malicious VPN), Zscaler can

: ▪ Step-up authentication (require additional MFA) ▪ Block access entirely ▪ Restrict to read-only access

2. Compromised Account Hunting: o Analysts query Zscaler logs to identify: ▪ Users accessing applications at unusual hours ▪ Unusual data transfer volumes (potential exfiltration

▪ Access from unusual geographic locations o Cross-reference with MISP to see if destination IPs are known malicious

3. Proactive Threat Blocking: o MISP feeds are pushed to ZIA for real-time enforcement o When any user attempts to access a blocked domain, the request is denied o Alerts are generated for security team investigation

• Incident Response in Zero Trust Model Incident response is fundamentally improved in a Zscaler Zero Trust environment. The ability to instantly revoke access and the inherent lack of lateral movement transforms how security teams respond to threats.

Incident Response Workflow: 1.

Detection: • Alert Trigger: The SOC receives an alert from Zscaler logs or integrated EDR tool. Example: A faculty account is downloading 50GB of research data at 3:00 AM, far exceeding normal behavior.

• Investigation Initiation: The analyst opens the Zscaler admin portal and views the session details: o User: Dr. Smith (Faculty_Research group) o Device: Laptop "FAC-LT-342" (Windows 11, Defender active) o Application: Research Data Repository (SMB share) o Data transferred: 50GB in 15 minutes o Source IP: Unusual location (country different from user's normal location) 2. Containment: • Instant User Isolation: The analyst navigates to the user profile in the Zscaler portal and clicks "Deactivate User" or "Block Device." This action: o Terminates all active Zscaler connections immediately o Prevents any new authentication attempts o Takes effect globally within seconds (no firewall rules to update)

• Impact of Containment: Because the user was never on the network, there is no lateral movement to contain. The attacker is limited to the single compromised application and cannot pivot. 3. Eradication:

• The compromised device is remotely wiped or taken offline by IT helpdesk. • The user's password is reset in Azure AD.

• The analyst checks MISP and Zscaler logs to determine how the account was compromised (e.g., phishing email received earlier that day).

• The malicious domain from the phishing email is added to Zscaler's block list (or automatically ingested via MISP). 4. Recovery:

• Once the device is clean (re-imaged or malware removed) and the password is reset, the analyst reenables the user in Zscaler. • The user authenticates with MFA from a clean device and regains access only to authorized applications. • All subsequent activity is closely monitored for 24-48 hours. 5. Post-Incident Review: • The security team analyzes the incident to identify root cause and process improvements.

• Zscaler policies are updated: perhaps additional restrictions on sensitive research data (e.g., require approval for downloads over 1GB). Benefits of ZTNA-Based Incident Response: 1. Containment Speed: Actions take seconds in a cloud dashboard versus hours reconfiguring firewall ACLs or disabling VPN accounts .

2. No Lateral Movement: The blast radius is limited to the single compromised application; the rest of the university network remains protected .

3. Complete Audit Trail: Zscaler provides granular logs of every connection, session, and data transfer for forensic analysis .

4. Remote-First Design: Incident response can be conducted entirely from the cloud, without requiring physical access to data center equipment .

5. Compliance Demonstration: The detailed logs and access controls help demonstrate compliance with FERPA, HIPAA (if applicable), and other regulations .

Conclusion: - In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In Stage 1, understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..

Considering the future scope, Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world. In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats. Future Scope: - Future of web application testing The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable. Here are some of the key trends that are expected to shape the future of WAT:

● Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.

● Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

● Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms.

Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.

● Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience. Future scope of the testing process The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable. Here are some of the key trends that are expected to shape the future of the testing process:

● Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

● Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods. ● Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms. ● Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

While the current project successfully replaces the legacy VPN with Zscaler ZPA for remote access, the Zero Trust journey offers several avenues for future expansion and enhancement:

1. **Workload-to-Workload Segmentation**: Extend Zero Trust principles beyond user-toapplication connectivity to secure communication between internal workloads themselves. By deploying Zscaler Workload Segmentation, the university can enforce micro-segmentation within the data center and cloud environments, preventing lateral movement

even between application tiers (e.g., web server to database server) without relying on network firewall rules.

2. Branch and Campus Transformation: Expand the Zscaler deployment to eliminate MPLS circuits and traditional hub-and-spoke networking. By routing all branch and campus internet traffic directly through Zscaler Internet Access (ZIA), the organization can reduce costs, improve performance, and apply consistent security policies to all users, regardless of their physical location.

3. OT and IoT Security Integration: Extend Zero Trust coverage to operational technology (OT) and Internet of Things (IoT) devices on campus, such as building management systems, security cameras, and lab equipment. Zscaler can provide visibility and segmentation for these often-unmanaged devices, ensuring they cannot be used as an entry point to attack core academic systems.

4. Advanced Data Loss Prevention (DLP): Enhance Zscaler deployment with advanced DLP capabilities to protect sensitive research data and student information. Future phases can include fingerprinting of sensitive documents, exact data matching (EDM) for structured data like student records, and integration with insider threat management tools to detect and block anomalous data exfiltration attempts.

5. AI-Driven Threat Hunting: Leverage Zscaler's AI-powered analytics and the integration with threat intelligence platforms like MISP to implement proactive threat hunting. Machine learning models can baseline normal user behavior and automatically flag anomalies—such as impossible travel or unusual data access patterns—for immediate investigation by the security operations center (SOC).

6. Privileged Remote Access for Vendors: Formalize and secure access for external vendors and contractors who require temporary access to specific systems for maintenance and support. Zscaler's privileged remote access capabilities can provide time-bound, session-recorded, and approval-based access to critical infrastructure without granting network-level privileges.

7. Integration with SOAR Platforms: Integrate Zscaler with security orchestration, automation, and response (SOAR) platforms to enable automated incident response workflows. For example, if Zscaler detects a compromised device, the SOAR platform can

automatically trigger service desk tickets, isolate the device from the network, and reset the user's Active Directory credentials.

8. Continuous Compliance Automation: Utilize Zscaler logs and APIs to automate compliance reporting for regulations such as FERPA, GDPR, and HIPAA. Future development can include real-time compliance dashboards that demonstrate least-privilege access, data protection controls, and audit readiness to regulators and internal auditors.

9. Zero Trust for Mergers and Acquisitions: As the university grows or partners with other institutions, Zscaler can provide a secure framework for rapidly integrating new users and applications. Zero Trust principles ensure that acquired entities can access specific resources without being placed on the internal network, maintaining security during transitional periods.

10. User Behavior Analytics (UBA): Implement advanced user behavior analytics to detect insider threats and compromised accounts. By analyzing patterns of application access, data transfer volumes, and login times, machine learning algorithms can identify subtle indicators of malicious activity that rule-based policies might miss.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds,Soc and Siem.

Tools explored: - Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END